Seguridad de los servicios

DNS

DNS

- Domain Name System (DNS) es un sistema globalmente distribuido, escalable y jerárquico.

- Ofrece una base de datos dinámica asociando direcciones IP de computadoras, servicios o cualquier recurso conectado a internet o red privada.

- Fundamentalmente, DNS se encarga de traducir direcciones IP de recursos de red a nombres fácilmente legibles y memorizables por las personas, y viceversa.

- Soporta tanto IPv4 como IPv6, y la información se almacena en forma de registros Resource Records (RR) de distintos tipos los cuales pueden almacenar direcciones IP u otro tipo de información.

- DNS está compuesto por un espacio de nombres de dominio organizados en jerarquía de árbol donde se enlazan nodos, cada uno representando un nivel del espacio de dominios.

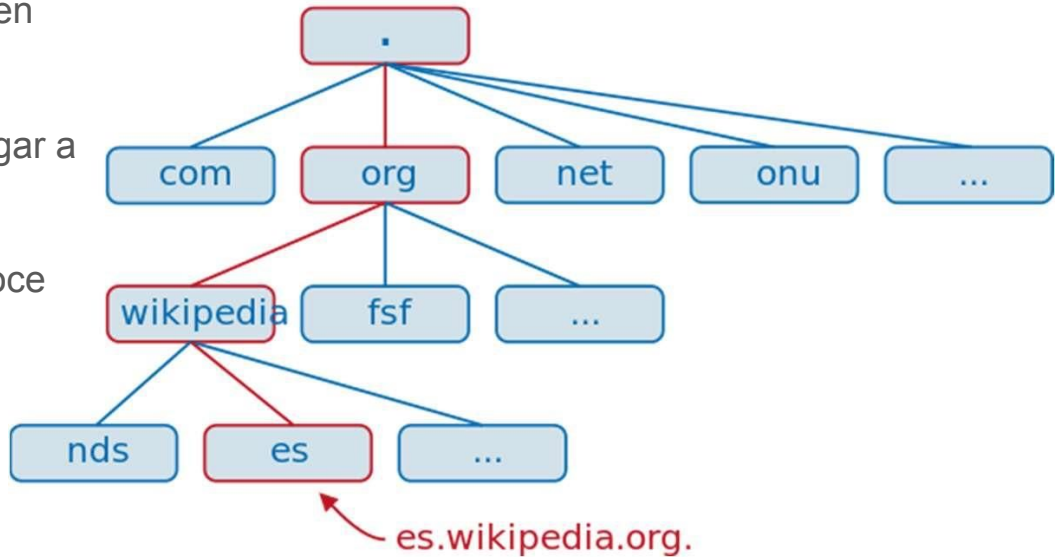
DNS - Estructura jerárquica

El nivel más alto de toda la jerarquía es el dominio raíz o root, representado por “.” (punto).

Justo un nivel por debajo se encuentran los Top Level Domains o TLDs. Éstos, a su vez, son nodos padre de otros niveles inferiores que se conocen como TLDs de segundo nivel.

Sucesivamente, la jerarquía continúa hasta llegar a un nodo final que representa un recurso.

El nombre formado por toda la cadena se conoce como **Fully Qualified Domain Name (FQDN)**.



DNS

Los servicios DNS son fundamentales para la navegación a través de la web. Sin embargo, este servicio es uno de los más vulnerables ante los ataques.

Una de las razones por las que el DNS es susceptible de recibir más ataques es por el protocolo usado en la capa de transporte, el UDP.

- UDP es un protocolo de transmisión connectionless.
- Prima la velocidad de la transmisión y sobre el cual se envía y recibe la información sin que se haya establecido previamente una conexión y sin confirmación ni control de entrega/recepción de la misma.
- Esto es lo que posibilita el falseo de direcciones IP o IP spoofing y la suplantación de mensajes de consulta/respuesta.
- Dada la carencia de control / confirmación en las transmisiones UDP, la responsabilidad final de validar un mensaje recaerá directamente sobre el protocolo DNS.

DNS

Dado que el protocolo DNS opera de forma nativa en la capa de aplicación sobre los puertos UDP/TCP 53, la integridad y confidencialidad del fichero de zona representan el raíz de la confianza para todos los servicios dependientes de la red: HTTP / HTTPS, SMTP / TLS, VPN, autenticación distribuida.

Un compromiso en el fichero de zona permite:

- la interceptación completa del tráfico,
- suplantación de identidad (Phishing),
- elusión de controles de seguridad (SPF / DKIM / DMARC) y
- mapeo detallado de la infraestructura interna.

DNS

Es importante leer el RFC 4033, DNS Security Introduction and Requirements

https://datatracker.ietf.org/doc/html/rfc4033

Mecanismo de resolución una consulta DNS

El cliente (resolver) hace llegar la consulta al servidor DNS:

- Si el servidor DNS es autoritativo y recibe una consulta DNS sobre un dominio sobre el que él es autoritativo, devolverá la respuesta consultando los registros almacenados en su configuración y devolviendo la respuesta marcada como **Authoritative Answer** en la sección “ANSWER” del mensaje de respuesta. Si no tiene la información, responde con el mensaje NXDOMAIN (Non-Existent-Domain).

- Si el servidor DNS es autoritativo y no configurado como recursivo y recibe una consulta sobre un dominio sobre el que no es autoritativo, responderá con un mensaje conteniendo registros en la sección “AUTHORITY” y en la sección ADDITIONAL informando al resolver que no proporciona recursión y donde debe dirigir su consulta para obtener información autoritativa del dominio solicitado. Se conoce como Referral Response.

- Si el servidor DNS no es autoritativo, pero está configurado como recursivo y recibe una consulta, éste inicia consultas iterativas (recursión) para encontrar el servidor autoritativo del dominio. Una vez obtiene respuesta devuelve el registro al cliente (resolver) indicando que se trata de una respuesta no autoritativa. La información la guarda en caché, de modo que si vuelve a ser preguntado por el mismo recurso y el tiempo con que el registro está marcado para “caducar” (TTL, o Time To Live) no ha pasado, contestará consultado esta caché.

Mensajes DNS

Las comunicaciones del DNS siguen un formato estándar llamado mensaje, que se divide en:

- Header
- Question
- Answer
- Authority
- Additional

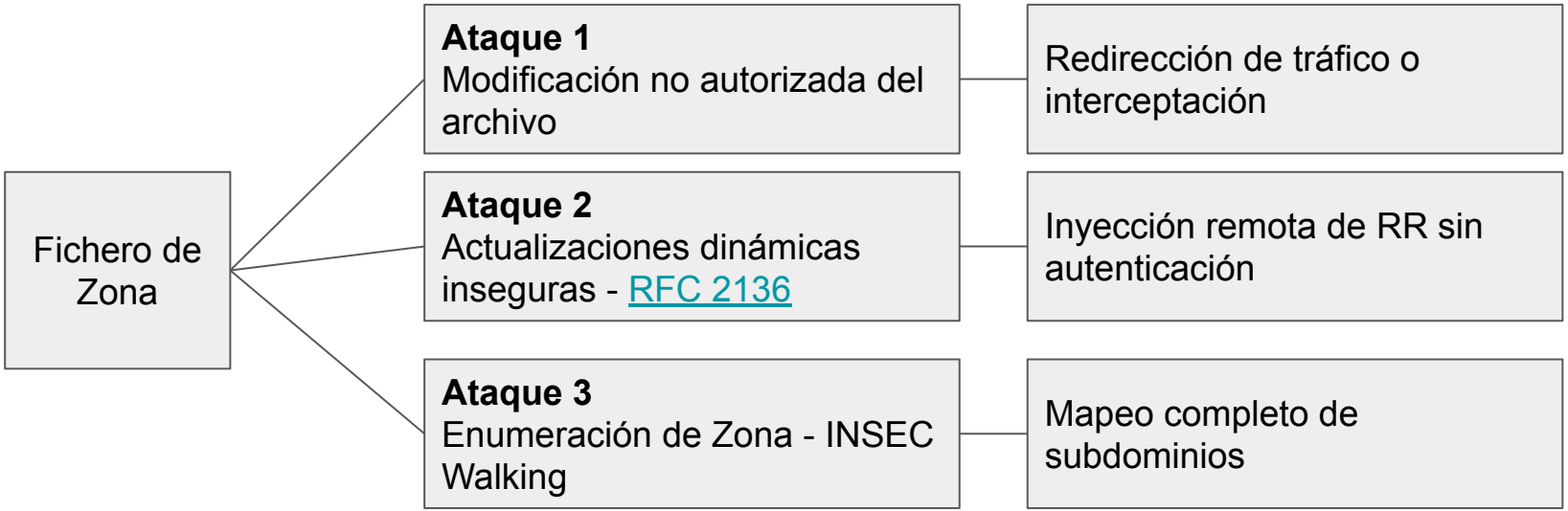
Dependiendo del tipo de mensaje alguna sección puede estar vacía, salvo el Header que siempre tiene información importante.

Mensajes DNS

SECCION	Descripción
HEADER	Contiene información sobre el tipo de mensaje. Incluye campos que informan sobre el número de entradas en otras secciones del mensaje.
QUESTION	Contiene una o más solicitudes de información (queries) que se envían al servidor DNS
ANSWER	Contiene uno o más registros que responden a la(s) solicitud(es)
AUTHORITY	Contiene uno o más registros que apuntan al servidor autoritativo del dominio en cuestión
ADDITIONAL	Registros con información adicional no necesaria para responder a la query

Administración - ficheros de zona

El fichero de zona es una base de datos en formato texto y administrada por el servidor DNS maestro que contiene los Registros de Recursos - RR que son los encargados de definir la delegación y resolución de un espacio de nombres particular: *A* - *AAAA* - *MX* - *NS* - *CNAME* - *TXT* - *PTR* - *SOA* - *DNSKEY*



Vectores de ataques

Transferencia de zonas

1. Es una transacción a través de la cual un servidor DNS secundario o esclavo actualiza los contenidos de zona desde un servidor primario o master de este modo, mantener una copia sincronizada con las base de datos maestra.
2. La transacción se inicia con un mensaje de transferencia de zona (zone transfer query) donde se solicitan todos los registros (resource records o RRs) de un dominio.
3. La solicitud de transferencia de zona se genera en el servidor secundario de forma automática bajo dos posibles circunstancias:
    a. Se recibe un mensaje de notificación <<NOTIFY>> por parte del primario para dar a conocer que se han producido cambios o modificaciones en los contenidos de la zona.
    b. Ha transcurrido el tiempo especificado en el valor <<Refresh>> del campo RDATA del registro SOA de la zona.

Actualizaciones dinámicas

En algunos entornos el número de registros y zonas crecen y varían frecuentemente, con lo que es inviable una gestión manual.

Por ejemplo - Los registros de nombres tipo “A” en un servicio de DHCP y sus inversos “PTR” dentro de una gran compañía proveedora de servicios.

De esta necesidad surge el concepto de actualización dinámica.

- El mecanismo de actualización dinámica proporciona dos operaciones: añadir o borrar registros en un fichero de zona.
- El caso de una actualización queda cubierto por un borrado y la posterior recreación del mismo.

La especificación detallada se puede consultar en el RFC 2136 Dynamic Updates in the Domain Name System (DNS UPDATE)

Actualizaciones dinámicas

Teniendo en cuenta las dos posibles operaciones añadir / borrar definidas en el proceso de actualización dinámica las posibles acciones pueden ser:

- Añadir o borrar registros individuales.
- Borrar conjuntos de registros que cumplan un criterio específico de un dominio determinado.
- Borrar un dominio existente como por ejemplo, todos los registros del dominio midominio.com.
- Añadir un nuevo dominio con uno o más registros.

Notificaciones y actualizaciones por transferencia de zona

Cada vez que se produce un cambio en los ficheros de zona del servidor autoritativo primario, el servidor secundario debe ser informado de dicha modificación y así proceder a actualizar su copia de las zonas, solicitando una transferencia de zona al primario.

Por este mecanismo, tras una modificación en los registros de zona, el servidor maestro manda un mensaje (NOTIFY) a los secundarios para advertir este cambio.

Adicionalmente, aunque menos preciso que el NOTIFY del primario, es el proceso de transferencia de zona desencadenado en el servidor secundario cuando ha caducado el valor “refresh” especificado en el registro SOA almacenado.

Por defecto, BIND utiliza el método de notificación NOTIFY.

Vectores de ataques y amenazas

Existe 5 áreas principales que presentan una superficie susceptible a amenazas.

- **Amenazas locales**: En la prevención de las amenazas locales, la solución más sencilla es la implementación de medidas y políticas de seguridad en la red interna. Mecanismos anti-spoofing, IDS/IPS, así como la protección de los canales de acceso a los servidores y sus archivos sentarán la línea base de protección en esta área.

- **Amenazas Servidor-Servidor**: Actualizaciones dinámicas. Presentes cuando el tamaño de la organización o el número de servidores a administrar obliga a centralizar la administración de los datos a través de DDNS (Dynamic DNS). Una opción válida para asegurar la comunicación sería dedicar un canal de comunicación restringido y/o implementar TSIG.

Vectores de ataques y amenazas

- **Amenazas Servidor Master - Servidor Esclavo**: Transferencias de zona. Cuando una organización cuenta con servidores esclavos, tiene la necesidad de ejecutar transferencias de zona maestro/esclavo. En estos casos la solución a considerar es la implementación de TSIG (Transaction SIGnature - Transferencia segura de zona), de modo que las operaciones de transferencia de zona se firmen con una clave conocida por ambas partes. Adicionalmente la seguridad en las comunicaciones puede reforzarse usando SSL/TLS. Otras opciones pasarían por un canal de red privado para la transacción, o en caso extremo deshabilitarla y realizarla manualmente, lo cual no es una alternativa funcional.

- **Amenazas Servidor Master - Servidor Cliente Caché/Resolver**. Se han implementado mejoras en las versiones recientes de Bind con la introducción de aleatoriedad en los puertos origen de la consulta, así como en los identificadores de mensaje, dificultando la posibilidad de envenenamiento de caché en los servidores DNS, pero aún así, el ataque sigue siendo posible. La única solución considerada efectiva es adoptar DNSSEC.

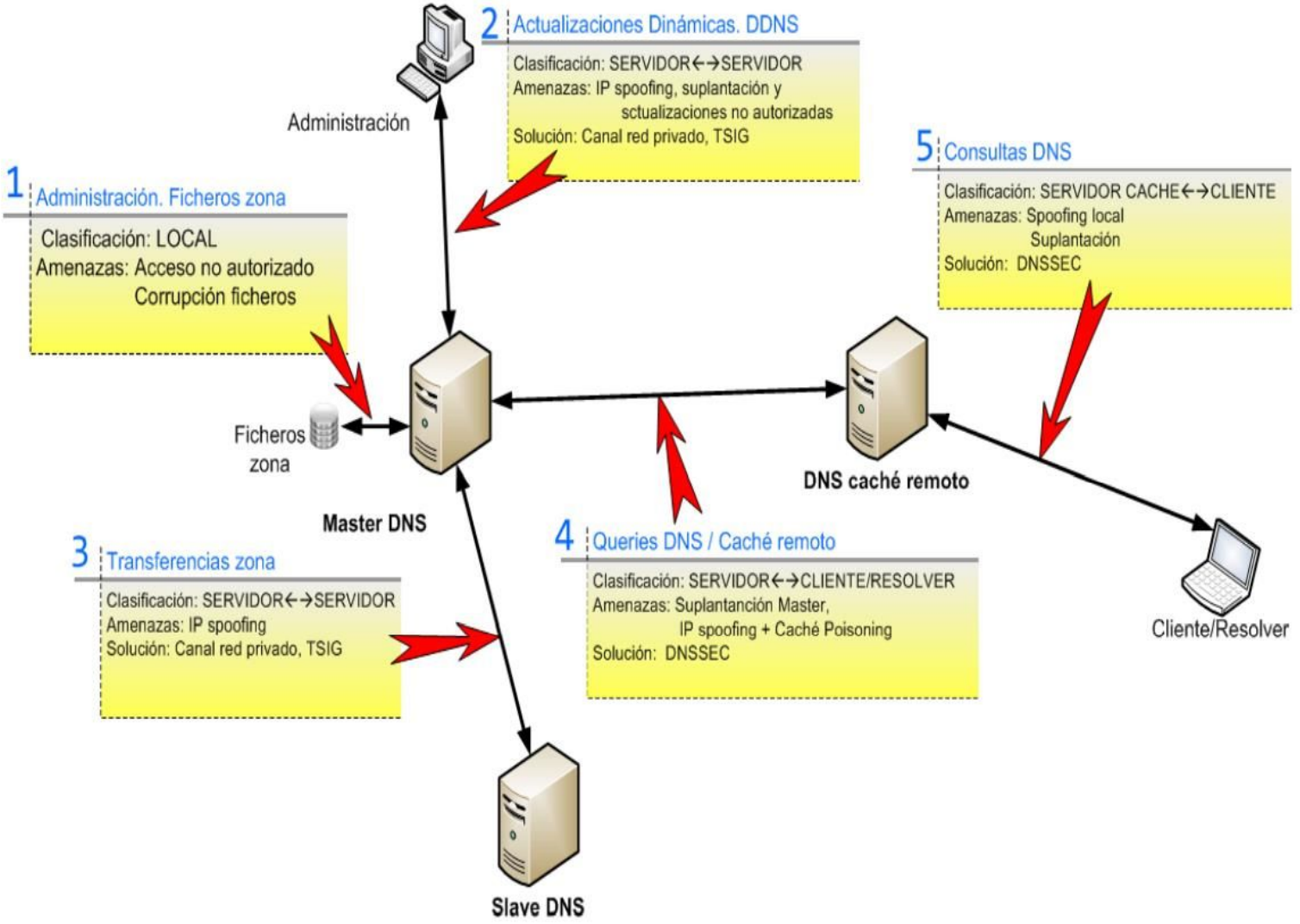
- **Servidor - Cliente**: En el flujo de información entre un cliente/resolver y un servidor master o caché, cabe la posibilidad de ataques locales para interceptar datos y de spoofing con el objetivo de suplantar al servidor DNS. La única solución considerada efectiva es adoptar DNSSEC.

DNSSEC

Añade autenticación a las respuestas mediante una firma digital.

- No cifra el tráfico entre clientes y/o servidores.
- No evita ataques de denegación de servicio.
- Se basa en una delegación de confianza entre zonas padres e hijas.
- Usa criptografía asimétrica - clave pública/privada.
- La zona raíz está firmada con una clave privada y la pública es conocida globalmente.
- Todas las consultas de registros vendrán acompañadas de un registro RRSIG.

Vectores de ataques del DNS



Vulnerabilidades del DNS

UDP y el IP Spoofing

- La principal debilidad es el uso del protocolo UDP.
- Se puede enviar y recibir información sin establecimiento de conexión previa.
- No hay confirmación ni control de la entrega/recepción de paquetes.
- Facilita el falseo de direcciones IP (IP Spoofing) .
- Facilita la suplantación de mensajes de consulta y respuesta.

Identificación y validación de mensajes

En la sección HEADER de un mensaje DNS se destina el campo ID para identificar el mismo. Este identificador, representado por un número de sólo 16 bits, juega un papel importante en el mecanismo de validación de mensajes de respuesta.

Debido a la escasa longitud destinada al campo ID del mensaje (16 bits) y a debilidades en la generación de la secuencia de los mismos, computacionalmente es relativamente sencillo construir un número suficiente de ID's en un tiempo limitado para conseguir "acertar" con el ID original.

Sin embargo, se han mejorado muchos aspectos en la fortificación del ID y otros valores en el mensaje DNS desde que, en 2008 Dan Kaminsky (un investigador en Seguridad IT), presentó su trabajo sobre "DNS Caché Poisoning", donde demostró lo sencillo que era conseguir falsificar una respuesta a una consulta DNS y de este modo, lograr que el servidor solicitante almacenase la misma en su caché.

Debilidad en la identificación y validación de mensajes DNS

Debilidad de diseño en el aspecto de la identificación y validación de paquetes favoreciendo la falsificación de estos Validación de respuestas: Es sencillo construir una respuesta falsa si se conoce el recurso solicitado.

Identificador del mensaje ID: Se puede generar un numero de ID’s en tiempo limitado que consigan acertar con el ID original logrando que el servidor solicitante almacene la respuesta en su caché.

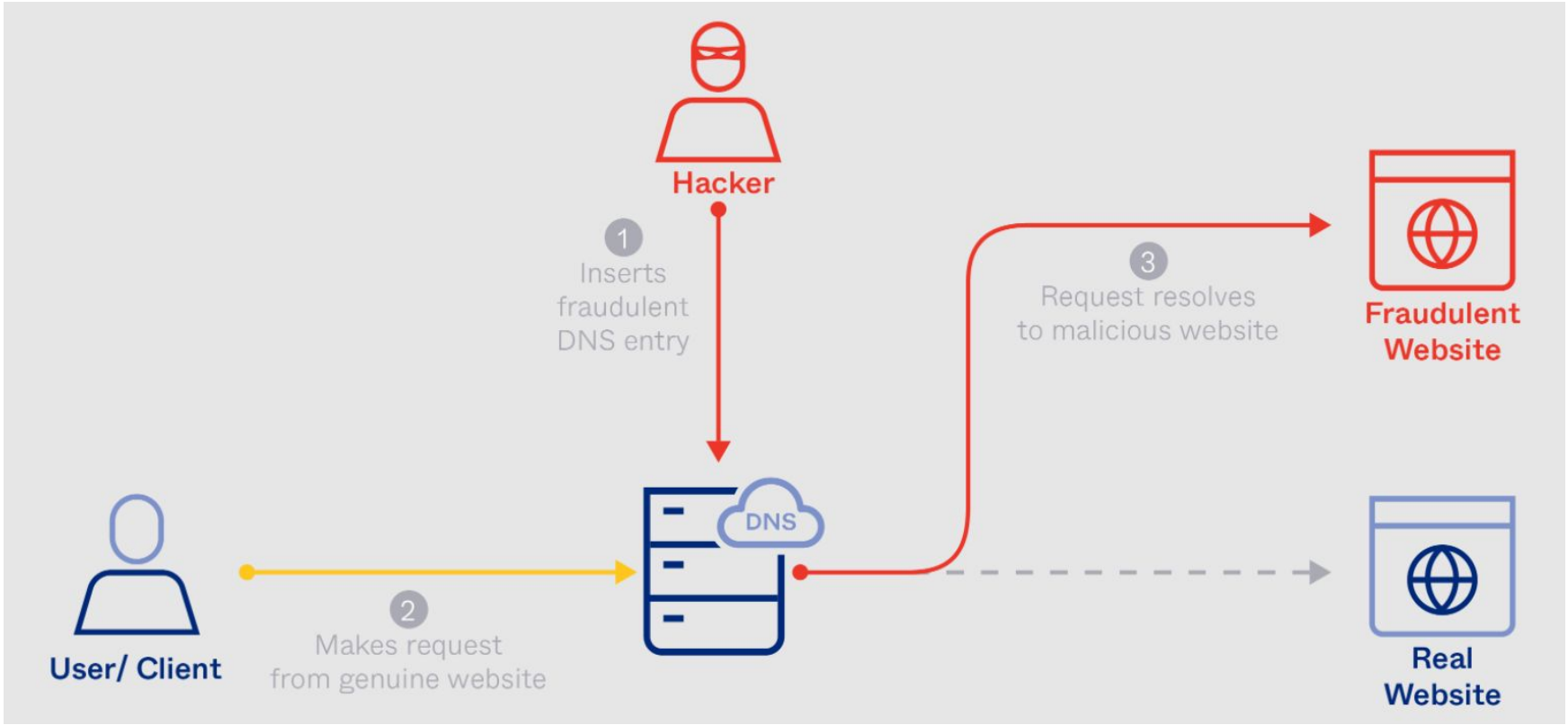
Ataques de DNS

IP Spoofing - Cache Poisoning - DDoS

El envenenamiento de caché de DNS consiste en introducir información falsa en una caché DNS, para que las consultas de DNS devuelvan una respuesta incorrecta y se dirija a los usuarios a sitios web equivocados (maliciosos).

El envenenamiento de caché de DNS también se conoce como "suplantación de DNS".

DNS Cache Poisoning - suplantación de DNS



DNS Cache Poisoning

- El atacante, con servidor DNS bajo su control, solicita un nombre que pertenezca al dominio al cual quiere suplantar.
- Se asegura que este nombre no esté cacheado.
- El servidor (víctima) no encuentra en su caché el recurso pedido, inicia la secuencia de peticiones iterativas a los servidores raíz y recorriendo los TLD que se le indican en los referrals hasta que sepa el servidor autoritativo del recurso, para dirigir la pregunta.
- En ese instante, el servidor malicioso inicia un bombardeo de respuestas con distintos ID con el objetivo de acertar en una de ellas con el ID coincidente con la query original del servidor víctima.
- En esas respuestas se indica que el servidor autoritativo (AUTHORITY) para el dominio a suplantar se encuentra en la IP del servidor malicioso.

DNS Cache Poisoning

- Si se consigue hacer llegar la respuesta falseada antes de que llegue la original, el servidor víctima almacenará en caché el registro falseado con la IP del servidor malicioso como servidor autoritativo suplantando al servidor legítimo.
- La respuesta legítima que llegará después será descartada.
- Envenenamiento de cache DNS completado exitosamente.

A partir de este momento todas las solicitudes de resolvers que le lleguen de subdominios pertenecientes al dominio suplantado se dirigirán al servidor malicioso que se encargará de ofrecer las IP bajo su control según le convenga.

Análisis - DNS Cache Poisoning y DNS Spoofing

En la arquitectura del protocolo DNS sobre UDP, la asociación entre una consulta enviada por un servidor recursivo y la respuesta recibida por el autoritativo se basa primariamente en un identificador de 16 bits ubicado en la sección de cabecera - HEADER y se denomina Transaction ID - TxID.

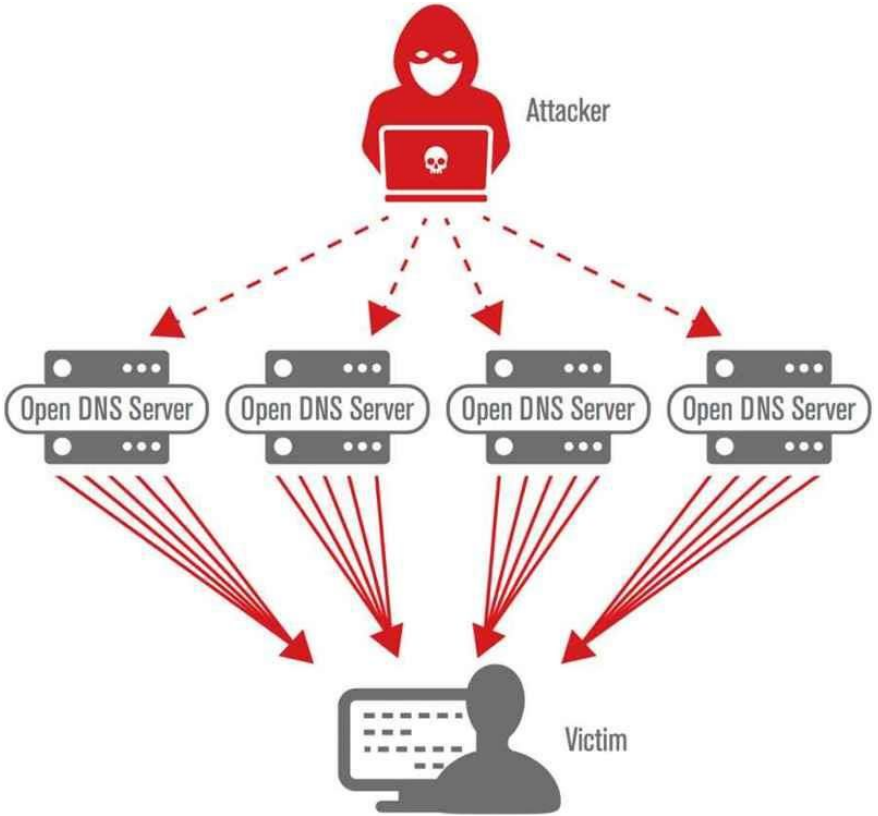
Cuando no se implementan mecanismos de validación adicionales, el servidor DNS recursivo asume que una respuesta es legítima si el TxID coincide con el de la petición pendiente.

Esto crea una ventana de vulnerabilidad basada en **condiciones de carrera - race conditions**: si un atacante es capaz de adivinar o iterar masivamente el TxID e inyectar un paquete antes de que retorne la respuesta auténtica, el servidor almacenará el registro adulterado.

Ataques de amplificación DNS - DDoS

El atacante envía consultas masivas a servidores DNS abiertos falsificando la IP de origen para que coincida con la IP de la víctima.

Los servidores responden enviando paquetes de gran tamaño hacia la víctima, saturando su ancho de banda y provocando la caída del servicio.

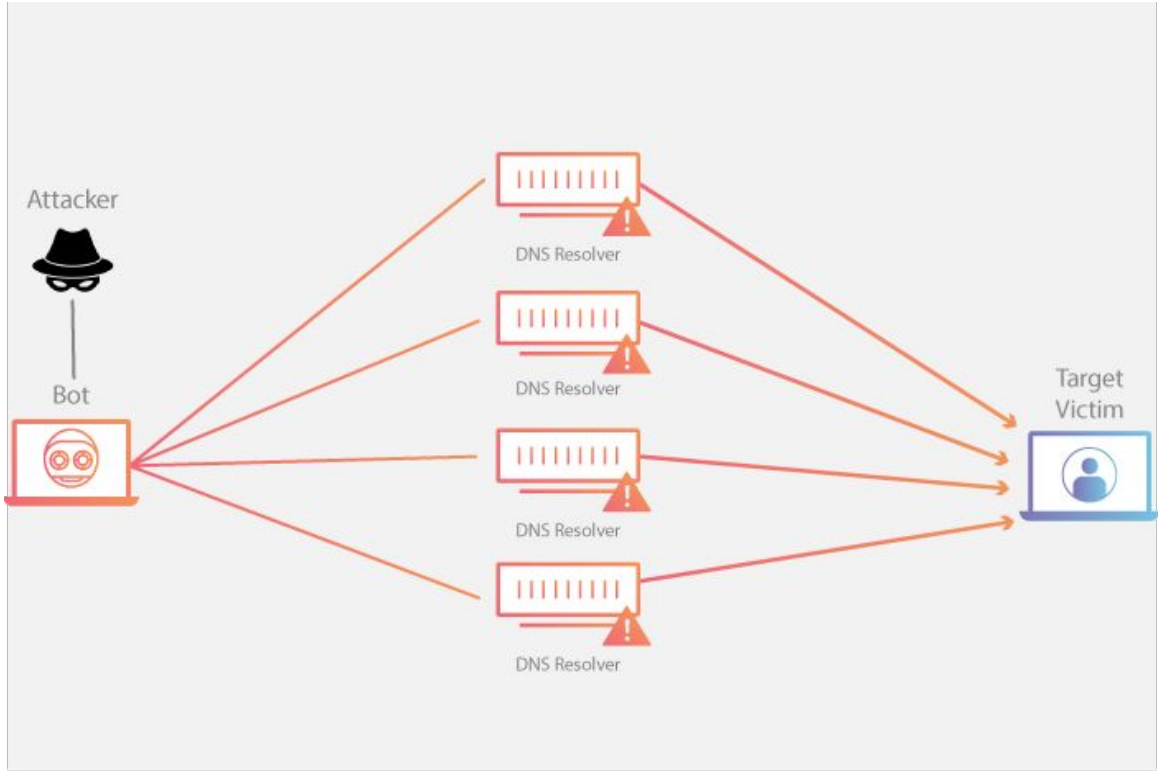


Ataque de amplificación de DNS

Es un ataque DDoS en el que un atacante aprovecha la funcionalidad de los resolvers de DNS abiertos para sobrecargar a un servidor o red de destino con una cantidad amplificada de tráfico, generando sobre el servidor y su infraestructura un volumen de tráfico que lo deje inaccesible.

Ataque de amplificación de DNS

En muchos casos el uso de una botnet con muchos equipos zombies incrementa aún si cabe su volumen y efectividad.



Preguntas

1. ¿Cuál es la secuencia detallada del ataque o flujo de explotación para el DNS Cache Poisoning, DNS Spoofing y del ataque de amplificación de DNS?
2. Busca e investiga si existe alguna herramienta para hacer ataques de envenenamiento de caché DNS (DNS cache poisoning).
3. Averigua qué medidas se pueden tomar para evitar el ataque de envenenamiento de caché DNS.
4. Busca e investiga si existe alguna herramienta para hacer ataques de amplificación de DNS.
5. Averigua qué medidas se pueden tomar para evitar el ataque DDoS de amplificación de DNS.

Links

- https://www.cloudflare.com/es-es/learning/dns/dns-security/
- https://www.incibe.es/sites/default/files/contenidos/guias/doc/incibe_guia_de_implantacion_y_buenas_practicas_de_dnssec.pdf
-